

Glosario Integral

1. Fundamentos generales de ciberseguridad

These foundational concepts underpin every other area of computer security. Master them first.

1. **CIA Triad (Confidentiality, Integrity, Availability)** — The foundational model of information security. Confidentiality ensures data is accessible only to authorized parties; Integrity ensures data remains accurate and unaltered; Availability ensures systems and data are accessible when needed.
2. **Authentication** — The process of verifying the identity of a user, device, or system. Common methods include passwords, biometrics, tokens, and cryptographic certificates. It answers: "Who are you?"
3. **Authorization** — The process of determining what actions or resources an authenticated entity is permitted to access. Authorization follows authentication and enforces access control policies based on roles, attributes, or predefined rules.
4. **AAA (Authentication, Authorization, and Accounting)** — A security framework whose third pillar, Accounting, involves tracking and logging user activities and resource usage. It provides audit trails for forensic analysis, compliance reporting, and detection of unauthorized actions.
5. **Multi-Factor Authentication (MFA)** — A mechanism requiring two or more independent verification factors — something you know (password), something you have (token/device), and/or something you are (biometric) — before granting access. MFA dramatically reduces the risk of compromised credentials.
6. **Encryption (Symmetric and Asymmetric)** — The conversion of plaintext into unreadable ciphertext using a cryptographic algorithm and key. **Symmetric encryption** uses a single shared key (e.g., AES); **asymmetric encryption** uses a public/private key pair (e.g., RSA, ECC).
7. **Hashing** — A one-way cryptographic function that converts input of any size into a fixed-length digest that cannot be reversed. Used for password storage, integrity verification, and digital signatures. Common algorithms: SHA-256, SHA-3.
8. **Digital Signature** — A cryptographic mechanism using asymmetric keys to verify authenticity and integrity. The sender signs with their private key; the recipient verifies with the sender's public key — providing authentication, integrity, and non-repudiation.
9. **PKI (Public Key Infrastructure)** — A framework of policies, hardware, software, and procedures for creating, managing, distributing, and revoking digital certificates. PKI

enables secure communications through a chain of trust anchored by Certificate Authorities.

- 10. Digital Certificate** — An electronic document issued by a CA that binds a public key to an entity's identity using the X.509 standard. Certificates enable parties to verify each other's identities in encrypted communications.
- 11. Certificate Authority (CA)** — A trusted third-party entity that issues, validates, and revokes digital certificates within a PKI. Well-known CAs include DigiCert, Let's Encrypt, and GlobalSign.
- 12. TLS (Transport Layer Security)** — A cryptographic protocol providing end-to-end encryption, authentication, and integrity for network data, most commonly securing HTTPS. The current version, TLS 1.3, replaced the deprecated SSL protocol.
- 13. SSH (Secure Shell)** — A cryptographic protocol for secure remote login, command execution, and file transfer. SSH uses public-key authentication and symmetric session encryption, replacing insecure predecessors like Telnet.
- 14. IPsec (Internet Protocol Security)** — A protocol suite that authenticates and encrypts IP packets at the network layer (Layer 3). It operates in Transport mode (encrypts payload) or Tunnel mode (encrypts the entire packet), widely used in VPN implementations.
- 15. Non-Repudiation** — A security property ensuring an entity cannot deny having performed a particular action. Achieved through digital signatures, audit logs, and timestamps; essential for legal and regulatory compliance.
- 16. OAuth 2.0** — An open authorization framework enabling third-party applications to obtain limited access to user resources without exposing credentials. Uses access tokens and is the basis for "Sign in with Google/Facebook" flows.
- 17. SAML (Security Assertion Markup Language)** — An XML-based standard for exchanging authentication and authorization data between an Identity Provider (IdP) and a Service Provider (SP). Enables enterprise Single Sign-On (SSO).
- 18. OpenID Connect (OIDC)** — An identity layer built atop OAuth 2.0 that adds authentication, allowing clients to verify user identity and obtain profile information using JSON Web Tokens.
- 19. JWT (JSON Web Token)** — A compact, URL-safe token format (RFC 7519) for securely transmitting claims between parties. Consists of three Base64-encoded parts: header, payload, and signature.
- 20. Access Control List (ACL)** — A list of permissions attached to a resource specifying which users or processes may access it and what operations they may perform. A fundamental discretionary access control mechanism.

- 21. RBAC (Role-Based Access Control)** — An access control model that assigns permissions to predefined roles rather than individual users. Users are then assigned roles (e.g., admin, editor, viewer), simplifying management at scale.
- 22. ABAC (Attribute-Based Access Control)** — A flexible model evaluating access requests based on attributes of the user, the resource, the action, and environmental conditions (time, location). More dynamic and granular than RBAC.
- 23. Principle of Least Privilege** — Users, processes, and systems should receive only the minimum access necessary to perform their authorized functions, limiting blast radius from breaches or errors.
- 24. Separation of Duties** — Critical tasks are divided among multiple individuals so no single person can commit fraud or cause major harm undetected. Foundational in financial systems and compliance frameworks.
- 25. Defense in Depth** — A layered security strategy employing multiple, overlapping controls across network, host, application, and data levels. If one layer fails, others continue protecting assets.
- 26. Attack Vector** — The specific path or method a threat actor uses to gain unauthorized access — phishing emails, unpatched vulnerabilities, compromised credentials, misconfigured services, etc.
- 27. Attack Surface** — The total set of possible entry points through which an attacker could access an organization's systems. Encompasses digital assets, physical assets, and human elements; expands as technologies are adopted.
- 28. Threat Actor** — Any individual, group, or entity posing a cybersecurity threat. Categorized as nation-states, cybercriminals, hacktivists, insider threats, or script kiddies, each with different motivations and capabilities.
-

2. Seguridad ofensiva

The attacker's perspective: reconnaissance through exploitation, persistence, and exfiltration.

Conceptos fundamentales

- 29. Penetration Testing (Pentesting)** — An authorized, simulated cyberattack against a system, network, or application to evaluate its security. Pentesters use the same tools and techniques as real attackers, then produce a report with findings and remediation guidance.

- 30. Vulnerability Assessment** — A systematic process of identifying, quantifying, and prioritizing security weaknesses. Unlike pentesting, it typically stops at discovery and classification without actively exploiting vulnerabilities.
- 31. Red Team** — Security professionals who simulate real-world adversarial attacks to test an organization's detection and response holistically. Engagements span weeks or months, targeting people, processes, and technology simultaneously.
- 32. Exploit** — Code, commands, or a technique that leverages a specific vulnerability to cause unintended behavior such as unauthorized access or privilege escalation. May target known or zero-day vulnerabilities.
- 33. Payload** — The component of an exploit that performs the actual malicious action on the target after successful exploitation — spawning a shell, exfiltrating data, deploying malware, etc.
- 34. Shellcode** — A small piece of machine code used as an exploit payload, typically designed to spawn a command shell. Written in assembly and position-independent, it is injected into a running process's memory.
- 35. Fuzzing (Fuzz Testing)** — An automated technique that feeds invalid, unexpected, or random data into a program to discover crashes and exploitable bugs. Modern fuzzers use coverage-guided and mutation-based strategies.

Reconocimiento y enumeración

- 36. Reconnaissance — Passive** — Gathering target information without direct interaction: WHOIS lookups, social media, DNS records, cached pages. Low detection risk.
- 37. Reconnaissance — Active** — Gathering information by directly interacting with the target (scanning, probing). Yields richer data but risks detection.
- 38. OSINT (Open Source Intelligence)** — Collection and analysis of publicly available information from websites, social media, government databases, and news to build target profiles. A cornerstone of the recon phase.
- 39. Footprinting** — Collecting maximum information about a target's IP ranges, domains, employees, network topology, and technology stack to identify attack vectors.
- 40. Enumeration** — Actively extracting detailed information — usernames, shares, services, routing tables — by establishing connections to the target. Goes beyond scanning to gather actionable data.
- 41. Port Scanning** — Identifying open ports and services on a host by sending packets and analyzing responses. Maps the attack surface and reveals potentially vulnerable services.

- 42. Banner Grabbing** — Capturing the initial response message from a service on an open port to identify software names, versions, and configurations. Enables matching to known vulnerabilities.

Técnicas de explotación

- 43. Buffer Overflow** — Writing more data to a memory buffer than it can hold, overwriting adjacent memory. Attackers exploit this to inject and execute arbitrary code. A critical vulnerability class in C/C++ applications.
- 44. SQL Injection (SQLi)** — Inserting malicious SQL into input fields to manipulate a database: reading, modifying, or deleting data, bypassing authentication, or achieving OS-level command execution.
- 45. Cross-Site Scripting (XSS)** — Injecting malicious client-side scripts (typically JavaScript) into web pages viewed by other users. Variants: Stored, Reflected, and DOM-based. Used to steal sessions, redirect users, or deface sites.
- 46. Cross-Site Request Forgery (CSRF)** — Forcing an authenticated user's browser to send forged requests to a vulnerable application, performing unwanted actions without the user's knowledge.
- 47. Command Injection** — Exploiting an application to execute arbitrary OS commands by passing unsanitized input to system functions like `system()` or `exec()`.
- 48. Remote Code Execution (RCE)** — A vulnerability class allowing an attacker to execute arbitrary code on a target remotely over a network. Among the most critical vulnerability types, often leading to full system compromise.
- 49. Reverse Shell** — A connection initiated from the victim machine back to the attacker, providing an interactive command shell. Bypasses firewalls that block incoming but allow outgoing connections.
- 50. Bind Shell** — The target opens a listening port and waits for the attacker to connect. Easier to block with firewalls but simpler to establish in unrestricted environments.

Post-explotación y movimiento lateral

- 51. Privilege Escalation — Vertical** — Gaining higher permissions than initially obtained (e.g., standard user → root/admin) by exploiting OS vulnerabilities, misconfigurations, or insecure service permissions.
- 52. Privilege Escalation — Horizontal** — Accessing resources of another user at the same privilege level, typically through flaws in access control or session management.

- 53. Lateral Movement** — Techniques used to move through a network after initial access, pivoting from one compromised system to others. Common methods: stolen credentials, trust relationships, RDP, SMB, PsExec.
- 54. Persistence** — Techniques to maintain access across reboots and credential changes: backdoors, new accounts, modified startup scripts, scheduled tasks, registry modifications, rootkits.
- 55. Pass-the-Hash (PtH)** — Using a captured NTLM password hash directly to authenticate to remote Windows systems without cracking the plaintext password. Exploits NTLM's hash-based verification.
- 56. Kerberoasting** — Requesting Kerberos service tickets (TGS) for Active Directory accounts with Service Principal Names, then cracking the encrypted ticket hashes offline. Any domain user can request these tickets.
- 57. Living off the Land (LotL / LOLBins)** — Using legitimate, pre-installed system tools (PowerShell, WMI, CertUtil, Rundll32) for malicious purposes. Extremely difficult to detect because the tools are trusted by the OS.
- 58. Pivoting** — Using a compromised system as a relay point to access internal networks not directly reachable from the attacker's position. Extends the attacker's reach deeper into the environment.

Ingeniería social

- 59. Social Engineering** — Psychological manipulation of people into performing actions or divulging confidential information, bypassing technical controls. Exploits cognitive biases: trust, urgency, fear, authority.
- 60. Phishing** — Mass social engineering via email, impersonating trusted entities to trick victims into clicking malicious links, opening infected attachments, or revealing credentials. The most common initial attack vector.
- 61. Spear Phishing** — Highly targeted phishing directed at a specific individual or organization, using personalized OSINT-derived information. Significantly more effective than generic campaigns.
- 62. Whaling** — Spear phishing targeting C-suite executives, board members, or senior management. Focuses on high-value actions like wire transfers or disclosure of sensitive corporate data.
- 63. Vishing (Voice Phishing)** — Social engineering via telephone or VoIP, impersonating banks, tech support, or government agencies to extract sensitive information.

- 64. Smishing (SMS Phishing)** — Deceptive text messages containing malicious links or prompts to call fraudulent numbers. Exploits the perceived trustworthiness of SMS.

Ataques a credenciales

- 65. Password Cracking** — Recovering plaintext passwords from hashes or encrypted stores using brute force, dictionaries, rainbow tables, or rule-based mutations. Key tools: Hashcat, John the Ripper.
- 66. Brute Force Attack** — Systematically trying every possible character combination until the correct password is found. Guaranteed success eventually, but computationally expensive for complex passwords.
- 67. Dictionary Attack** — Using a precompiled wordlist of likely passwords rather than exhaustive combinations. Faster than brute force but limited to passwords in (or derivable from) the list.
- 68. Rainbow Table** — A precomputed lookup table mapping hashes to plaintexts for rapid reverse lookup. Rendered ineffective by **salted** hashing algorithms.
- 69. Credential Stuffing** — Automated testing of leaked username/password pairs from prior breaches against other services. Exploits widespread password reuse.

Ataques de red y suplantación

- 70. Man-in-the-Middle (MITM)** — Secretly intercepting and potentially altering communications between two parties who believe they are communicating directly. Used for eavesdropping, credential theft, and content injection.
- 71. Session Hijacking** — Taking over an active session by stealing or predicting a valid session token, allowing impersonation of the legitimate user.
- 72. ARP Spoofing** — Sending falsified ARP messages on a LAN to associate the attacker's MAC address with a legitimate IP (e.g., the gateway), redirecting traffic for MITM attacks.
- 73. DNS Spoofing (DNS Cache Poisoning)** — Injecting forged DNS records into a resolver's cache, redirecting users to attacker-controlled servers. Used for phishing, malware distribution, and traffic interception.
- 74. IP Spoofing** — Creating IP packets with a falsified source address to impersonate another system or bypass IP-based access controls. Common in DDoS amplification attacks.

Vectores de entrega web

- 75. Watering Hole Attack** — Compromising websites frequently visited by the target group and injecting malicious code. Leverages trust in legitimate, familiar sites.
- 76. Drive-by Download** — Malware automatically downloaded and installed simply by visiting a compromised or malicious website, often without user interaction, exploiting browser or plugin vulnerabilities.
- 77. Exploit Kit** — A pre-packaged toolkit automating exploitation of client-side browser and plugin vulnerabilities. Fingerprints the victim's software, selects an exploit, and delivers a payload.

“HERRAMIENTAS OFENSIVAS CLAVE”

- 78. Metasploit** — An open-source penetration testing framework providing exploit modules, payloads (including Meterpreter), encoders, and auxiliary modules for recon and post-exploitation.
 - 79. Nmap (Network Mapper)** — An open-source tool for network discovery and security auditing: host discovery, port scanning, service/version detection, OS fingerprinting, and NSE scripting.
 - 80. Burp Suite** — An integrated platform for web application security testing: HTTP(S) proxy interception, automated scanning, and manual tools (Repeater, Intruder, Decoder).
-

3. Seguridad defensiva

The defender's toolbox: detection, response, forensics, and intelligence.

Operaciones de seguridad

- 81. Security Operations Center (SOC)** — A centralized facility staffed by analysts who continuously monitor, detect, analyze, and respond to cybersecurity incidents. The nerve center for defensive operations, leveraging SIEM, EDR, and threat intelligence.
- 82. SIEM (Security Information and Event Management)** — A platform that collects, aggregates, correlates, and analyzes logs and security events from diverse sources to detect threats and support compliance. Modern SIEMs incorporate UEBA and machine learning.

- 83. EDR (Endpoint Detection and Response)** — A solution that monitors endpoint devices in real time, recording activities to detect suspicious behavior. Uses behavioral analysis and can automatically isolate compromised endpoints.
- 84. XDR (Extended Detection and Response)** — Evolution of EDR that unifies telemetry across endpoints, network, cloud, email, and identity into a single platform. Provides holistic visibility and coordinated automated response.
- 85. MDR (Managed Detection and Response)** — An outsourced service combining advanced detection technology with human expert analysis for 24/7 threat monitoring, investigation, and incident response.
- 86. SOAR (Security Orchestration, Automation, and Response)** — Solutions that integrate security tools and automate incident response workflows via predefined playbooks. Orchestrates actions like blocking IPs, quarantining endpoints, and enriching alerts.
- 87. NDR (Network Detection and Response)** — Real-time network traffic monitoring using ML and behavioral analytics to detect threats like lateral movement, exfiltration, and C2 communications.
- 88. Log Analysis** — Examining log data from systems, applications, and security tools to identify anomalies, policy violations, and indicators of compromise. Fundamental to detection, forensics, and compliance.

Técnicas de detección

- 89. Signature-based Detection** — Comparing observed data against a database of known threat signatures. Highly accurate for known threats but cannot detect novel or polymorphic malware.
- 90. Behavioral Analysis / Heuristic Detection** — Identifying threats by analyzing behavior rather than known signatures. Uses rules and algorithms to flag suspicious characteristics, enabling detection of unknown variants.
- 91. Anomaly Detection** — Establishing baselines of normal behavior and flagging significant deviations. Can identify novel threats and insider attacks but may produce higher false-positive rates.
- 92. Sandboxing** — Executing suspicious files in an isolated virtual environment to observe behavior safely. Reveals malicious actions (network connections, file changes, registry modifications) without risking production systems.
- 93. Static Analysis** — Examining malware without executing it: disassembly, string extraction, header analysis. A rapid first step in malware triage.

- 94. **Dynamic Analysis** — Executing malware in a controlled environment to observe runtime behavior: process creation, file system changes, network communications. Reveals actual capabilities.
- 95. **Reverse Engineering** — Deconstructing compiled software to understand its internal workings at the assembly level. Essential for analyzing sophisticated malware and developing detection signatures.
- 96. **YARA Rules** — An open-source pattern-matching language for identifying and classifying malware based on textual strings, binary patterns, and boolean logic. Enables detection across files, memory, and data streams.
- 97. **Sigma Rules** — A vendor-agnostic, YAML-based detection rule format for SIEM systems. Convertible into platform-specific queries (Splunk, Elastic, Sentinel), complementing YARA's file-based matching.

Inteligencia de amenazas

- 98. **Threat Intelligence** — Evidence-based knowledge about existing or emerging threats — context, mechanisms, indicators, and actionable advice — informing proactive defense and resource allocation.
- 99. **Cyber Threat Intelligence (CTI)** — The structured discipline of collecting, processing, and disseminating information about adversaries. Categorized as strategic, tactical, operational, or technical.
- 100. **Indicators of Compromise (IOC)** — Observable artifacts (malicious IPs, file hashes, domains, registry keys) indicating a system has been breached. Reactive — used for detection and response after compromise.
- 101. **Indicators of Attack (IOA)** — Behavioral patterns signaling an active attack in progress, focusing on intent and techniques rather than specific artifacts. Proactive and technique-focused.
- 102. **STIX (Structured Threat Information eXpression)** — A JSON-based language for representing and sharing threat intelligence in machine-readable format. Models data as interconnected objects: indicators, malware, campaigns, threat actors.
- 103. **TAXII (Trusted Automated eXchange of Intelligence Information)** — A companion protocol to STIX for securely transporting threat intelligence over HTTPS. Supports hub-and-spoke, peer-to-peer, and source/subscriber sharing models.
- 104. **Threat Intelligence Platform (TIP)** — A system that aggregates, correlates, enriches, and operationalizes threat intelligence from multiple sources. Distributes IOCs to defensive tools and provides context for decisions.

- 105. Cyber Kill Chain (Lockheed Martin)** — A seven-phase model of a cyberattack: Reconnaissance → Weaponization → Delivery → Exploitation → Installation → Command & Control → Actions on Objectives. Enables defenders to disrupt attacks at each stage.

Equipos defensivos

- 106. Blue Team** — The defensive security group responsible for monitoring, detection, incident response, vulnerability management, and security hardening. Operates SOC and manages defensive tooling.
- 107. Purple Team** — A collaborative function integrating Red and Blue Team operations through shared knowledge, real-time feedback, and coordinated exercises. Ensures attack simulations directly improve defenses.
- 108. Threat Hunting** — Proactive, analyst-driven searching through networks and datasets to detect advanced threats that evade automated controls. Based on hypotheses from intelligence, analytics, and anomaly indicators.

Respuesta a incidentes

- 109. Incident Response (IR)** — The structured process of identifying, managing, containing, and recovering from cybersecurity incidents. Follows frameworks like **NIST SP 800-61** and SANS, executed by CSIRTs.
- 110. Incident Response Plan (IRP)** — A formal document defining roles, responsibilities, communication protocols, escalation paths, and technical steps for responding to incidents. Regularly tested through exercises.
- 111. Triage** — Initial assessment and prioritization of alerts to determine severity, scope, legitimacy, and urgency. Ensures the most critical threats receive immediate attention.
- 112. Containment** — Limiting the spread and impact of an incident by isolating affected systems, blocking malicious communications, and disabling compromised accounts. Includes short-term and long-term strategies.
- 113. Eradication** — Completely removing all traces of a threat — malware, backdoors, compromised accounts — and patching exploited vulnerabilities.
- 114. Recovery** — Restoring affected systems to normal operation from clean backups, with enhanced monitoring to detect recurrence.

- 115. **Lessons Learned / Post-Incident Review** — A retrospective conducted after incident resolution to evaluate the response, identify improvements, and update plans, controls, and training.
- 116. **Chain of Custody** — A documented record tracking the handling and storage of digital evidence from collection through legal proceedings. Essential for preserving evidence integrity and admissibility.

Análisis forense digital

- 117. **Digital Forensics** — The application of scientifically validated methods to identify, preserve, collect, examine, and present digital evidence. Supports incident response, criminal investigations, and regulatory compliance.
- 118. **Disk Imaging** — Creating a bit-for-bit forensic copy of a storage device (including deleted files and unallocated space) using tools like FTK Imager or EnCase. Hash verification ensures integrity.
- 119. **Memory Forensics** — Analyzing volatile memory (RAM) to extract running processes, network connections, encryption keys, and injected code. Critical for investigating fileless malware and rootkits operating entirely in memory.
- 120. **Network Forensics** — Capturing and analyzing network traffic to detect intrusions and reconstruct attack timelines. Examines PCAPs, flow data, and DNS logs.
- 121. **Malware Analysis** — Studying malicious software (via static, dynamic, and reverse engineering techniques) to understand functionality, origin, and impact. Informs detection signatures and remediation.

Seguridad de endpoints y tecnología de engaño

- 122. **Endpoint Security** — Securing devices that serve as network entry points: desktops, laptops, servers, mobile, IoT. Encompasses antivirus, EDR, host firewalls, application control, and encryption.
- 123. **Antivirus / Antimalware** — Software detecting and removing malicious software. Traditional engines use signatures; modern solutions add heuristic, behavioral, ML, and cloud-based detection.
- 124. **Data Loss Prevention (DLP)** — Tools and strategies that identify, monitor, and protect sensitive data at rest, in motion, and in use. Automatically block or encrypt transfers violating security policies.
- 125. **Honeypot** — A decoy system mimicking a legitimate target to attract attackers. Collects intelligence on TTPs and serves as early warning. Classified as low-interaction (simulated) or high-interaction (full OS).

- 126. **Honeynet** — A network of interconnected honeypots simulating a full production environment, enabling observation of complex multi-system attack patterns.
- 127. **Canary Token** — A lightweight deceptive artifact (fake document, URL, credential, API key) that triggers an alert when accessed. Near-zero false positives — any interaction signals malicious activity.
- 128. **Deception Technology** — Solutions deploying decoys, lures, and breadcrumbs throughout an environment. Modern platforms automate deployment, integrate with SIEM/SOAR, and provide high-fidelity alerts.

Divulgación y gestión de vulnerabilidades

- 129. **Vulnerability Disclosure** — Reporting discovered vulnerabilities to the affected vendor following policies (aligned with ISO 29147) that balance informing defenders with giving vendors time to patch.
- 130. **Bug Bounty** — Programs incentivizing external researchers to find and responsibly report vulnerabilities for rewards. Platforms: HackerOne, Bugcrowd, Intigriti.
- 131. **Threat Modeling** — A structured methodology for identifying and prioritizing potential threats by analyzing attack surfaces, threat actors, and vulnerabilities. Frameworks: STRIDE, PASTA, VAST.

4. Administración de la seguridad

Governance, risk, compliance, and the organizational structures that make security work.

Marcos y estándares

- 132. **NIST Cybersecurity Framework (CSF)** — A voluntary framework from the National Institute of Standards and Technology for managing cybersecurity risk. **CSF 2.0** (February 2024) is built around six core functions: **Govern, Identify, Protect, Detect, Respond, Recover**, with new emphasis on governance and supply chain risk.
- 133. **ISO 27001** — The international standard specifying requirements for an Information Security Management System (ISMS). Organizations can be **certified** against it by demonstrating systematic risk management through defined policies and controls.
- 134. **ISO 27002** — A companion standard providing a reference set of security controls and implementation guidance for the controls listed in ISO 27001's Annex A.
- 135. **COBIT (Control Objectives for Information and Related Technologies)** — An IT governance framework from ISACA aligning IT goals with business objectives. COBIT

2019 covers processes, organizational structures, and policies for enterprise IT management.

- 136. **PCI DSS (Payment Card Industry Data Security Standard)** — Security standards from the PCI Security Standards Council for protecting cardholder data. Prescribes **12 requirement areas** covering network security, access control, encryption, and monitoring.
- 137. **GDPR (General Data Protection Regulation)** — The EU's comprehensive data protection regulation (2018) governing personal data of EU residents. Mandates data minimization, consent, individual rights, and imposes fines up to **4% of annual global turnover**.
- 138. **SOC 2 (Service Organization Control 2)** — An AICPA auditing framework evaluating controls against five Trust Services Criteria: Security, Availability, Processing Integrity, Confidentiality, and Privacy. SOC 2 Type II reports are widely required for SaaS and cloud providers.

Gestión del riesgo

- 139. **Risk Management** — The ongoing process of identifying, assessing, prioritizing, and mitigating risks to organizational assets. Encompasses threat identification, vulnerability analysis, impact evaluation, and control implementation.
- 140. **Risk Assessment** — Systematically identifying threats and vulnerabilities, analyzing likelihood and impact. May be qualitative (descriptive scales), quantitative (numerical probabilities), or hybrid.
- 141. **Risk Appetite / Risk Tolerance** — **Risk appetite** is the broad level of risk an organization accepts in pursuit of objectives; **risk tolerance** defines specific, measurable boundaries. Together they guide security investment decisions.
- 142. **GRC (Governance, Risk, and Compliance)** — An integrated approach coordinating governance structures, risk management, and compliance activities. GRC platforms help align security with business objectives and streamline regulatory adherence.

Políticas y planificación

- 143. **Security Policy** — A formal document defining security objectives, roles, responsibilities, acceptable behavior, and rules governing information asset protection. The foundation from which standards and procedures derive.
- 144. **Acceptable Use Policy (AUP)** — Outlines permitted and prohibited uses of organizational IT resources. Sets expectations for employee behavior and specifies consequences for violations.

- 145. **Disaster Recovery Plan (DRP)** — Documented procedures for restoring critical IT systems after a disruptive event. Defines **Recovery Time Objectives (RTO)**, **Recovery Point Objectives (RPO)**, backup strategies, and communication protocols.
- 146. **Business Continuity Plan (BCP)** — A comprehensive plan for maintaining essential business functions during and after a disruption. Broader than DRP, covering personnel, facilities, supply chains, and communications.
- 147. **Business Impact Analysis (BIA)** — Identifies and evaluates potential effects of disruptions — financial loss, operational downtime, reputational damage, regulatory consequences. Directly informs DRP and BCP priorities.
- 148. **IT/Security Governance** — The system of policies, structures, and processes by which leadership directs and monitors IT and security activities. Establishes accountability and ensures cybersecurity risk is part of enterprise risk management.
- 149. **Tabletop Exercise** — A discussion-based simulation where stakeholders walk through a hypothetical incident scenario. Identifies procedural gaps and improves coordination without disrupting operations.

Gestión de vulnerabilidades

- 150. **Vulnerability Management Program** — A continuous process of identifying, classifying, prioritizing, remediating, and validating security vulnerabilities. Involves scanning, threat intelligence correlation, risk-based prioritization, and patch deployment.
- 151. **CVSS (Common Vulnerability Scoring System)** — An open framework rating vulnerability severity from 0.0 to 10.0. **CVSS v4.0** (November 2023) uses Base, Threat, Environmental, and Supplemental metric groups.
- 152. **CVE (Common Vulnerabilities and Exposures)** — A standardized ID system (e.g., CVE-2024-12345) maintained by MITRE for publicly disclosed vulnerabilities. Provides a common reference across tools and organizations.
- 153. **CWE (Common Weakness Enumeration)** — A MITRE taxonomy classifying root causes of vulnerabilities (e.g., CWE-79 for XSS, CWE-89 for SQLi). While CVE identifies specific instances, CWE categorizes underlying weakness types.
- 154. **NVD (National Vulnerability Database)** — NIST's comprehensive database synchronized with CVE. Enriches entries with CVSS scores, CWE classifications, affected product info (CPE), and patch references.
- 155. **Patch Management** — Identifying, acquiring, testing, and deploying software updates to address known vulnerabilities. Effective programs prioritize by severity, test in staging, and track deployment across the organization.

Otros conceptos de gestión

- 156. **SLA (Service Level Agreement)** — A contract defining measurable performance expectations: uptime, response times, security requirements, and penalties for non-compliance.
- 157. **Asset Management** — Identifying, inventorying, classifying, and tracking all hardware, software, data, and network resources. You cannot protect what you don't know you have.
- 158. **Data Classification** — Categorizing data by sensitivity (public, internal, confidential, restricted). Enables proportional security controls and handling procedures.
- 159. **Security Audit** — A systematic evaluation of security controls, policies, and procedures against established standards. May be internal or external; produces findings and recommendations.
- 160. **Third-Party Risk Management (TPRM)** — Assessing and monitoring cybersecurity risks from vendors, suppliers, and partners with access to organizational systems or data. Involves due diligence questionnaires, contractual requirements, and ongoing monitoring.
- 161. **Supply Chain Risk Management (SCRM)** — Identifying and mitigating risks from the hardware, software, and service supply chain: compromised updates, counterfeit components, malicious code insertion. Emphasized in NIST CSF 2.0.
- 162. **PTaaS (Penetration Testing as a Service)** — Continuous or on-demand pentesting through a service platform, combining automated scanning with manual expert testing and real-time results.
- 163. **Security Awareness Training** — Ongoing education teaching employees to recognize and report threats like phishing and social engineering. Combines training modules, simulated attacks, and assessments.

5. Monitorización y arquitecturas de seguridad

Network controls, cloud security, and the architectural patterns that protect modern infrastructure.

Controles de red

- 164. **Firewall** — A device monitoring and controlling traffic based on rules. **Stateless** firewalls filter by header info alone; **stateful** firewalls track connections; **NGFW (Next-Generation Firewalls)** add application-layer inspection, integrated IPS, and threat intelligence.

- 165. **IDS (Intrusion Detection System)** — Monitors network traffic or host activity for malicious behavior. Operates passively — detects and alerts but does not block threats.
- 166. **IPS (Intrusion Prevention System)** — Sits inline with traffic and actively blocks detected threats by dropping packets, blocking connections, or resetting sessions. Extends IDS with automated prevention.
- 167. **WAF (Web Application Firewall)** — Filters HTTP/HTTPS traffic to protect web applications against application-layer attacks (SQLi, XSS, CSRF). Inspects requests and responses against configurable rulesets.
- 168. **NAC (Network Access Control)** — Enforces policies on which devices and users may connect to a network. Authenticates and assesses device security posture (patches, antivirus) before granting access; quarantines non-compliant devices.
- 169. **Network Segmentation** — Dividing a network into smaller, isolated subnetworks to limit lateral movement, contain breaches, and enable granular policy enforcement.
- 170. **Microsegmentation** — Granular segmentation at the workload level within data centers or cloud environments. Enforces policies per individual workload, application, or process — far more precise than subnet/VLAN segmentation.
- 171. **DMZ (Demilitarized Zone)** — A perimeter segment between the internal network and the internet hosting public-facing services (web servers, email gateways). Firewalls on both sides control traffic flow.

Acceso remoto y conectividad

- 172. **VPN (Virtual Private Network)** — Creates an encrypted tunnel over a public network for secure remote access. Uses IPSec, SSL/TLS, or WireGuard. Increasingly supplemented by ZTNA.
- 173. **Proxy Server** — An intermediary forwarding client requests to the internet. Provides caching, content filtering, anonymization, and logging.
- 174. **Reverse Proxy** — Sits in front of backend servers, intercepting incoming requests. Provides load balancing, SSL termination, caching, and shields backend identities.
- 175. **Load Balancer** — Distributes traffic across multiple backend servers to optimize performance and ensure high availability. Also provides health monitoring, SSL offloading, and DDoS absorption.
- 176. **Bastion Host / Jump Server** — A hardened server serving as the sole administrative entry point to a private network. Runs minimal services; all sessions routed through it for centralized logging and control.

Marcos arquitectónicos modernos

- 177. **Zero Trust Architecture (ZTA)** — A security model: "**never trust, always verify.**" Requires continuous verification of every user and device, enforces least privilege, microsegmentation, and assumes any component may already be compromised.
- 178. **ZTNA (Zero Trust Network Access)** — Technologies providing identity-based, least-privilege access to specific applications (not broad network access). Deny-by-default, verifying identity and device posture. Increasingly replacing traditional VPNs.
- 179. **SASE (Secure Access Service Edge)** — A cloud-native architecture (Gartner, 2019) converging SD-WAN with security services (SWG, CASB, ZTNA, FWaaS) into a unified, globally distributed platform.
- 180. **SSE (Security Service Edge)** — The security subset of SASE (without SD-WAN): consolidates SWG, CASB, ZTNA, and FWaaS into a single cloud-delivered platform. Defined by Gartner in 2021.
- 181. **SD-WAN (Software-Defined Wide Area Network)** — Uses software-defined principles to manage WAN connections across multiple transport types. Provides centralized management, intelligent routing, and forms the networking half of SASE.

Seguridad en la nube

- 182. **Cloud Security** — Policies, technologies, and controls protecting cloud environments (IaaS, PaaS, SaaS). Operates under a **shared responsibility model**: the provider secures infrastructure; the customer secures data, configurations, and access.
- 183. **CASB (Cloud Access Security Broker)** — A policy enforcement point between cloud consumers and providers. Provides visibility into cloud usage, enforces data security, detects threats, and offers DLP, encryption, and anomaly detection.
- 184. **CSPM (Cloud Security Posture Management)** — Continuously monitors cloud configurations to identify misconfigurations, compliance violations, and security risks. Can automate remediation recommendations.
- 185. **CWPP (Cloud Workload Protection Platform)** — Protects cloud workloads (VMs, containers, serverless) across public, private, and hybrid clouds. Offers vulnerability scanning, runtime protection, integrity monitoring, and application whitelisting.

Gestión de identidades y acceso privilegiado

- 186. **IAM (Identity and Access Management)** — A framework managing digital identities and controlling resource access. Encompasses authentication (SSO, MFA, biometrics), authorization (RBAC/ABAC), and user lifecycle management.

- 187. PAM (Privileged Access Management)** — Securing, controlling, monitoring, and auditing privileged accounts (admins, root, service accounts). Provides password vaulting, session recording, just-in-time access, and least-privilege enforcement.

Monitorización de red

- 188. Network Monitoring** — Continuous observation of network traffic, performance, and availability using tools and protocols (SNMP, ICMP) to detect anomalies and security incidents.
- 189. NetFlow / sFlow** — Protocols exporting metadata about IP traffic flows. NetFlow (Cisco) and sFlow (industry standard, statistical sampling) enable bandwidth analysis, anomaly detection, and forensics without full packet capture.
- 190. Packet Capture (PCAP)** — Intercepting and recording complete network packets for analysis using tools like Wireshark or tcpdump. Provides the deepest level of network visibility.
- 191. Deep Packet Inspection (DPI)** — Examining both header and payload of packets at the application layer. Enables application identification, malware detection, DLP, and content filtering.
- 192. SSL/TLS Inspection** — Intercepting encrypted HTTPS traffic, decrypting it for threat inspection, then re-encrypting before forwarding. Critical for maintaining visibility into the growing volume of encrypted traffic.
- 193. Network TAP (Test Access Point)** — A passive hardware device creating an exact copy of all traffic on a link for monitoring tools. Preferred over SPAN/mirror ports for full-fidelity, lossless capture.
- 194. Air Gap** — Physical isolation of a computer or network from all unsecured networks. Used for classified systems and critical infrastructure, though still vulnerable to insider threats and physical access attacks.
- 195. Security Architecture** — The overarching design of an organization's security infrastructure: technologies, processes, standards, and principles defining how controls are implemented and integrated.
-

6. MITRE ATT&CK y OWASP

Industry-standard frameworks that provide a shared language for threats and vulnerabilities.

MITRE ATT&CK

- 196. **MITRE ATT&CK Framework** — A curated knowledge base of adversary TTPs based on real-world observations, organized into matrices for Enterprise, Mobile, and ICS. Used for detection mapping, gap analysis, red teaming, and threat intelligence.
- 197. **Tactics (MITRE)** — The adversary's tactical objective — the "why" behind an action. The Enterprise matrix includes **14 tactics**: Initial Access, Execution, Persistence, Privilege Escalation, Defense Evasion, Credential Access, Discovery, Lateral Movement, Collection, Command and Control, Exfiltration, Impact, Reconnaissance, and Resource Development.
- 198. **Techniques (MITRE)** — Describe "how" an adversary achieves a tactic. Each tactic contains multiple techniques (e.g., Phishing under Initial Access), many with sub-techniques for granular detail.
- 199. **TTPs (Tactics, Techniques, and Procedures)** — The behavioral patterns of threat actors. Tactics = goals, Techniques = methods, Procedures = specific implementations observed in the wild. Central to threat intelligence and adversary profiling.

OWASP

- 200. **OWASP (Open Web Application Security Project)** — A global nonprofit producing community-led open-source tools, documentation, and standards for software security. Resources include the OWASP Top 10, ASVS, and testing guides.
- 201. **OWASP Top 10 (2021)** — The ten most critical web application security risks: A01-Broken Access Control, A02-Cryptographic Failures, A03-Injection, A04-Insecure Design, A05-Security Misconfiguration, A06-Vulnerable and Outdated Components, A07-Identification and Authentication Failures, A08-Software and Data Integrity Failures, A09-Security Logging and Monitoring Failures, A10-SSRF.
- 202. **Broken Access Control (A01)** — Failures in enforcing user permissions, allowing unauthorized functionality or data access, data modification, or privilege escalation.
- 203. **Cryptographic Failures (A02)** — Formerly "Sensitive Data Exposure." Covers weak algorithms, improper key management, cleartext transmission, and missing encryption at rest or in transit.

204. **Injection (A03)** — Untrusted data sent to an interpreter as part of a command or query: SQLi, NoSQL injection, OS command injection, LDAP injection. XSS is now merged into this category.
205. **Insecure Design (A04)** — Introduced in 2021, focusing on fundamental architectural flaws rather than implementation bugs. Cannot be fixed by perfect implementation alone — requires threat modeling and secure design patterns.
206. **Security Misconfiguration (A05)** — Improperly configured security settings: default credentials, open cloud storage, unnecessary services, verbose error messages, permissive CORS. One of the most commonly encountered categories.
207. **Server-Side Request Forgery — SSRF (A10)** — A vulnerability where a web application fetches remote resources from a user-supplied URL without validation, enabling access to internal services, cloud instance metadata, or internal network scanning.
-

7. Tipos de malware y amenazas, y términos emergentes 2024–2025

From classic threat categories to the cutting edge of AI-era security.

Tipos de malware y amenazas clásicas

208. **Malware** — Umbrella term for malicious software. Major types include: **Virus** (self-replicating, attaches to programs), **Worm** (self-propagating across networks), **Trojan** (disguised as legitimate software), **Rootkit** (hides deep in the OS for persistent access), **Spyware** (secretly monitors activity), **Adware** (displays unwanted ads), **Ransomware** (encrypts data, demands payment), and **Fileless Malware** (operates in memory using system tools, leaves no files on disk).
209. **Ransomware** — Malware that encrypts victim files or locks systems, demanding ransom (usually cryptocurrency) for decryption keys. Modern variants use **double extortion** — threatening to leak stolen data if unpaid.
210. **Advanced Persistent Threat (APT)** — A sophisticated, prolonged attack campaign, typically by well-resourced (often nation-state) actors, that maintains undetected access over extended periods. Uses multiple vectors, custom malware, and social engineering.
211. **Supply Chain Attack** — Compromising a trusted third-party vendor or software component to attack downstream targets. Notable examples: SolarWinds (2020), Codecov, and 3CX (2023).

- 212. Zero-Day Vulnerability / Exploit** — A previously unknown flaw for which no patch exists. "Zero-day" = developers have had zero days to fix it. Highly valued by both attackers and vulnerability brokers.
- 213. Botnet** — A network of compromised devices (bots/zombies) remotely controlled via C2 infrastructure. Used for DDoS, spam, malware distribution, cryptomining, and credential stuffing at scale.
- 214. Command and Control (C2/C&C)** — Infrastructure and channels used to manage compromised systems: issue commands, exfiltrate data, deploy malware. May use HTTP/S, DNS tunneling, social media, or encrypted protocols.
- 215. DDoS (Distributed Denial of Service)** — Multiple compromised systems flood a target with traffic, rendering it unavailable. Targets bandwidth, server resources, or application layers. Measured in Gbps or requests/second.
- 216. Backdoor** — A covert method of bypassing authentication, installed by developers for maintenance or implanted by attackers. Provides persistent, often undetected access.
- 217. Keylogger** — Software or hardware that records keystrokes to capture passwords, card numbers, and sensitive data. Software-based variants run as hidden processes; hardware variants attach to keyboards.

Términos emergentes 2024–2025

- 218. AI-Powered Attacks** — Cyberattacks enhanced by AI/ML: AI-generated phishing, automated vulnerability discovery, adaptive evasive malware, AI-assisted recon, and deepfake social engineering. Reduces attacker effort while increasing scale and sophistication.
- 219. Prompt Injection** — Manipulating an LLM application via crafted inputs to bypass safety guardrails or produce unintended outputs. **Direct** (user supplies malicious prompt) or **indirect** (malicious instructions embedded in data the LLM processes). Ranked **#1 risk** in the OWASP Top 10 for LLM Applications (2025).
- 220. LLM Security** — The discipline of defending against threats specific to Large Language Model applications: prompt injection, sensitive information disclosure, training data poisoning, model theft, excessive agency, and supply chain risks in model components.
- 221. OWASP Top 10 for LLM Applications (2025)** — Community-driven list of critical LLM risks: LLM01-Prompt Injection, LLM02-Sensitive Information Disclosure, LLM03-Supply Chain, LLM04-Data and Model Poisoning, LLM05-Improper Output Handling, LLM06-Excessive Agency, LLM07-System Prompt Leakage, LLM08-Vector and Embedding Weaknesses, LLM09-Misinformation, LLM10-Unbounded Consumption.

- 222. Adversarial Machine Learning** — Exploiting ML model vulnerabilities through evasion attacks (causing misclassification), data poisoning (corrupting training data), model extraction (stealing parameters), and inference attacks (extracting private training data).
- 223. Model Poisoning** — Manipulating a trained model's weights or architecture to introduce hidden backdoors or biased outputs while maintaining normal performance on standard inputs. Demonstrated by the PoisonGPT attack on open-source models.
- 224. Data Poisoning** — Corrupting training data to cause a model to learn incorrect patterns. Can be targeted (affecting specific inputs) or indiscriminate.
- 225. Deepfake-based Social Engineering** — Using AI-generated synthetic audio, video, or images to impersonate trusted individuals for fraud or unauthorized access. Includes deepfake voice calls authorizing wire transfers and video impersonation in virtual meetings.
- 226. AI Red Teaming** — Structured adversarial testing of AI systems to uncover vulnerabilities, safety issues, and unintended behaviors. Tests for prompt injection, data poisoning, bias, and harmful outputs. Formalized by CISA, NIST, and major AI companies.
- 227. Shadow AI** — Unauthorized use of AI tools (ChatGPT, Claude, Midjourney) by employees without IT/security oversight. Creates risks of data leakage, compliance violations, and uncontrolled attack surface expansion. IBM's 2025 research found shadow AI involved in **20% of data breaches** globally.
- 228. Post-Quantum Cryptography (PQC)** — Algorithms secure against both classical and quantum computers. In **August 2024, NIST finalized three PQC standards**: FIPS 203 (ML-KEM), FIPS 204 (ML-DSA), and FIPS 205 (SLH-DSA). Migration is urgent to counter "**harvest now, decrypt later**" threats.
- 229. Passkeys / FIDO2** — Phishing-resistant, passwordless credentials based on the FIDO2 standard (WebAuthn + CTAP2). Use public-key cryptography with the private key on the user's device, unlocked via biometrics or PIN. Synced across devices via cloud services, eliminating passwords entirely.
- 230. Confidential Computing** — Protects data in use by performing computations within hardware-based Trusted Execution Environments (TEEs) — secure CPU enclaves isolated from the OS, hypervisor, and cloud provider. Complements encryption at rest and in transit.
- 231. CTEM (Continuous Threat Exposure Management)** — A Gartner framework (Scope → Discover → Prioritize → Validate → Mobilize) for continuously identifying and remediating exposures across the full attack surface. Unlike periodic scanning,

validates real-world exploitability. Gartner predicts a **two-thirds breach reduction** by 2026 for adopters.

- 232. Attack Surface Management (ASM)** — Continuously discovering, inventorying, and monitoring all internet-facing and internal assets — including shadow IT — to identify and reduce potential attack points. A key input to CTEM programs.

- 233. Cybersecurity Mesh Architecture (CSMA)** — A Gartner-introduced composable architecture enabling interoperability among disparate security tools through four layers: Analytics & Intelligence, Distributed Identity Fabric, Consolidated Policy Management, and Integrated Dashboards. Suited for hybrid multi-cloud and distributed environments.

- 234. Identity Threat Detection and Response (ITDR)** — A framework (coined by Gartner, 2022) for detecting identity-based attacks — credential theft, privilege escalation, compromised identity misuse — in real time. Complements IAM and PAM with behavioral analytics and automated response.

- 235. Secure by Design** — A CISA-championed initiative embedding security into every SDLC phase from the outset: default secure configurations, elimination of vulnerability classes, transparency, and accountability shifted to software manufacturers.

- 236. Software Bill of Materials (SBOM)** — A machine-readable inventory of all components, libraries, and dependencies in a software application. Mandated by US Executive Order 14028 (2021). Enables rapid identification of exposure to new vulnerabilities (e.g., Log4j). Common formats: **SPDX** and **CycloneDX**.

Conclusión

This glossary of **236 terms** maps the full landscape of computer security as it stands in 2025 — from timeless fundamentals like the CIA triad and defense in depth to the newest frontiers of post-quantum cryptography, LLM security, and AI red teaming. Three patterns stand out. First, the boundary between offense and defense is increasingly fluid: Purple Teams, CTEM, and ASM reflect a profession that no longer treats attack and defense as separate disciplines. Second, identity has become the new perimeter — the rise of ZTA, ZTNA, ITDR, PAM, and Passkeys/FIDO2 shows that trust is no longer granted by network location but continuously verified per request. Third, AI is simultaneously the most powerful new weapon and the most novel new attack surface: terms like prompt injection, shadow AI, and adversarial ML did not exist in most syllabi two years ago but are now essential knowledge. For students at ESCOM-IPN, fluency in these terms — in English, as the global industry uses them — is the foundation upon which every technical skill in this field is built.